ACCUMEDICAL
ACCURATE BILLING & MEDICAL AUDIT S.A.

INFORME TÉCNICO · CONFIDENCIAL

Plataforma Accumedical: arquitectura, tecnología y seguridad

Accurate Billing & Medical Audit S.A. Septiembre 2026 Versión 1.0

1 · RESUMEN EJECUTIVO

Qué es la plataforma y bajo qué principios está construida.

Accumedical es una **plataforma modular para el sector de seguros de salud**: un núcleo compartido (aseguradoras, prestadores y su red de convenios, usuarios con roles y permisos, auditoría) sobre el que se montan módulos de negocio independientes, organizados en dos familias comerciales:

- **Suscripción** — Examen de Asegurabilidad, Formulario de Declaración de Salud (DST) y Calificación de Riesgo.
- **Siniestro** — Carta de Vida y **Auditoría de Concurrencia**, el primer módulo construido de punta a punta: bandeja de casos por aseguradora, derivación a médicos auditores, aplicación móvil de campo con dictado por voz, informes redactados por IA, PDF de marca con firma electrónica y envío por correo.

Tres principios rigen todo el diseño: **la seguridad se decide en el servidor** (el frontend solo pinta), **ningún dato se destruye** (borrado lógico y auditoría inmutable en todo el sistema) y **la arquitectura escala por adición**: incorporar un módulo nuevo es una fila de catálogo, sus tablas propias y su carpeta — cero cambios sobre lo existente.

2 · STACK TECNOLÓGICO

Tecnologías en producción, por capa. Versiones fijadas por archivos de bloqueo.

Servidor y datos

PIEZA	TECNOLOGÍA	PAPEL
Lenguaje / API	Python 3.12 · FastAPI	API REST bajo `/api/v1`, documentación OpenAPI solo en desarrollo
Base de datos	PostgreSQL 16	SQLAlchemy 2.0 (ORM parametrizado) y migraciones versionadas con Alembic
Validación	Pydantic v2	Todo dato de entrada se valida en el servidor, nunca solo en el cliente
Sesiones	Tabla propia, token opaco	256 bits, guardado solo como SHA-256; revocación con efecto inmediato
Contraseñas	argon2id	Estándar actual de hashing; mínimo 12 caracteres

Interfaces

PIEZA	TECNOLOGÍA	PAPEL
Web	React 18 · TypeScript · Vite	SPA estática servida por nginx Tailwind + shadcn/ui, TanStack Query, React Router v6, Framer Motion, Zustand (solo estado de UI)
Móvil	Expo SDK 57 · React Native 0.86	App nativa del médico auditor (Android e iOS) expo-audio (dictado), expo-image-picker (fotos de expediente), expo-secure-store (llavero), expo-file-system y expo-sharing (PDF)
Diseño	Design tokens propios	Marca navy/oro con modo claro y oscuro en web y app; acento por módulo desde el catálogo, nunca hardcodeado

Inteligencia y documentos

PIEZA	TECNOLOGÍA	PAPEL
Redacción de informes	Claude (Anthropic)	Redacta el informe de auditoría desde las notas dictadas *y las fotos del expediente* (visión), con instrucciones de fidelidad absoluta; también aplica correcciones dictadas por el médico
Transcripción de voz	Whisper local (faster-whisper)	El dictado clínico se transcribe **dentro del propio servidor**, en CPU: el audio no sale a ningún servicio externo y se borra apenas transcrito
PDF de marca	reportlab	El informe con la identidad de la empresa, renderizado al vuelo — no se persisten archivos
Firma electrónica	pyHanko (PAdES)	Firma digital con el certificado .p12 de la empresa; sello visible y verificación en Adobe
Correo	SMTP con TLS	Avisos e informes con membrete de marca (logo incrustado en el mensaje) y reintento ante redes inestables

Infraestructura

PIEZA	TECNOLOGÍA	PAPEL
Contenedores	Docker + docker-compose	Cuatro servicios (api, web, db, nginx), contenedores sin root también en desarrollo, imágenes multi-stage con etiqueta fijada
Proxy	nginx	Sirve la SPA y da proxy a la API; cabeceras de seguridad en cada `location`
Dependencias	uv.lock · package-lock.json	Instalación solo desde archivos de bloqueo (`uv sync --frozen` , `npm ci`)

3 · SEGURIDAD WEB — OWASP TOP 10 (2021)

Cada riesgo del estándar, con la defensa concreta implementada en la plataforma.

A01 Control de acceso roto — CUBIERTO

Autorización **solo en el backend**, con dependencias declaradas a nivel de router para que todo endpoint nuevo nazca protegido, y **denegación por defecto**. RBAC por módulo + verificación de acceso en cada petición (sin caché: revocar surte efecto inmediato) + *ownership* por aseguradora en toda consulta. Un test de CI recorre todas las rutas y rompe la construcción si alguna queda sin autenticar. El acceso indebido responde 403 genérico, sin filtrar qué existe.

A02 Fallos criptográficos — CUBIERTO

Contraseñas con **argon2id**; token de sesión opaco de 256 bits guardado únicamente como SHA-256; cookie `httpOnly + Secure + SameSite=Strict` (prefijo `__Host-` en producción); HTTPS forzado en nginx. Los secretos que deben poder leerse de vuelta (contraseña del certificado de firma, secreto MFA) se guardan **cifrados con Fernet** bajo una llave derivada del secreto del servidor con HKDF: robarse el disco no basta sin el entorno.

A03 Inyección — CUBIERTO

Solo ORM parametrizado — **cero SQL crudo y cero f-strings en consultas**, incluida la búsqueda por similitud. Validación Pydantic de toda entrada. En el frontend, prohibido `dangerouslySetInnerHTML`; en los correos HTML, todo contenido pasa por escape.

A04 Diseño inseguro — CUBIERTO

El login lleva **tres capas**: límite por IP en nginx, límite por endpoint (slowapi) y bloqueo por cuenta en la base con un único UPDATE atómico. La respuesta es idéntica en todos los fallos y la verificación argon2 se ejecuta siempre, para que ni el texto ni el tiempo de respuesta permitan enumerar usuarios.

A05 Configuración incorrecta — CUBIERTO

`DEBUG=False` validado al arranque en producción (la app se niega a arrancar mal configurada); contenedores sin root; secretos solo por variables de entorno validadas con pydantic-settings; CSP estricta sin `unsafe-inline`, HSTS, X-Frame-Options, X-Content-Type-Options y Referrer-Policy en cada `location` de nginx; CORS con lista blanca explícita, jamás `*`.

A06 Componentes vulnerables — CUBIERTO

Única vía de instalación: los archivos de bloqueo (`uv sync --frozen`, `npm ci`). `pip-audit` y `npm audit` como pasos bloqueantes de CI, e imágenes base con etiqueta fijada y vigente.

A07 Fallos de autenticación — CUBIERTO

Rotación del identificador de sesión al iniciar sesión; expiración por inactividad (30 min) y absoluta (12 h); logout que invalida **en el servidor**; desactivar un usuario revoca todas sus sesiones al instante. MFA preparado desde el esquema (secreto TOTP cifrado), pendiente de activar en la interfaz.

A08 Fallos de integridad — CUBIERTO

CSRF de doble envío en todas las mutaciones del navegador, ligado a la sesión; el login solo acepta `application/json`. Toda subida (logos, comprobantes, fotos clínicas, audio, certificado de firma) se valida por **contenido real** — python-magic o apertura criptográfica del archivo —, con tope de tamaño, renombrada con UUID, almacenada fuera del árbol ejecutable y servida sin posibilidad de ejecución.

A09 Fallos de registro y monitoreo — CUBIERTO

AuditLog inmutable (trigger en base) con usuario, módulo, acción, entidad, IP y user-agent, escrito *en la misma transacción* que cada mutación de negocio. Logs estructurados en JSON correlacionados por request-id. Lista de denegación central: contraseñas, tokens y **datos clínicos jamás tocan un log** — de una nota dictada solo se registran tipo y longitud.

A10 SSRF — CUBIERTO

El servidor no hace ninguna petición saliente a URLs suministradas por usuarios. Sus tres únicas salidas están fijadas en código o configuración del despliegue: la API de Anthropic (URL constante), el servidor SMTP propio y nada más. El logo por URL está prohibido: solo subida de archivo.

4 · SEGURIDAD DE LA APLICACIÓN MÓVIL

La app del médico auditor sigue los lineamientos de OWASP MASVS en sus frentes clave.

Almacenamiento de credenciales

El token de sesión vive en el **llavero del sistema** (Keychain en iOS, Keystore en Android), cifrado por el teléfono y fuera del alcance de otras apps. La regla de la casa «nunca un token en localStorage» tiene aquí su equivalente nativo correcto.

Sesión y revocación

El mismo token opaco del navegador, en otro sobre: cabecera `Authorization: Bearer` contra la misma tabla de sesiones. Revocar la sesión, desactivar al usuario o cerrar sesión surte efecto **al instante también en el teléfono**. La vía Bearer queda exenta de CSRF por diseño razonado: sin cookies automáticas no hay diputado confundido que proteger.

Datos clínicos en el dispositivo

El audio dictado se sube y **se descarta**; las notas y fotos viven en el servidor, no en el teléfono; el PDF descargado va a la caché del sistema. La app no mantiene base de datos local con información de pacientes.

Permisos y ownership

Micrófono y cámara se piden en el momento de uso, con textos de propósito declarados. El servidor impone el *ownership* del auditor: solo ve los casos derivados a él — el caso ajeno responde 404 indistinguible de uno inexistente.

5 · PROTECCIÓN DEL DATO CLÍNICO

El dato más sensible de la plataforma tiene su propio perímetro.

- **La voz no sale de casa.** La transcripción del dictado corre con Whisper *dentro del servidor propio*; ningún audio clínico viaja a servicios de terceros, y el archivo se borra apenas transcrito.
- **Los logs no saben medicina.** De notas, fotos e informes, el registro de auditoría guarda solo metadatos (tipo, longitud, tamaño): el contenido clínico jamás se escribe en un log.
- **La IA recibe lo mínimo y por un solo canal.** El informe se redacta contra la API de Anthropic por una URL constante en código, con clave solo en el entorno del servidor; las correcciones del médico son la autoridad final sobre el texto.
- **El informe viaja firmado.** El PDF sale con firma electrónica PAdES del certificado de la empresa — quién firmó, cuándo, y si el documento fue alterado después — gestionado desde el panel del administrador con la contraseña cifrada en reposo.
- **Nada se borra de verdad.** Todo el sistema usa borrado lógico: un dato retirado conserva quién y cuándo lo retiró.

6 · TRABAJO EN CURSO

Lo que está preparado y aún no activado — dicho con claridad.

Despliegue de producción y CI

EN CURSO

El compose de producción y la tubería de integración continua (con las auditorías de dependencias como pasos bloqueantes) están definidos en el plan y pendientes de montar; el diseño de seguridad ya los asume.

MFA

PREPARADO

El esquema guarda el secreto TOTP cifrado desde el primer día; falta la pantalla de alta y verificación.

Notificaciones push

PREPARADO

El auditor ya recibe correo y la app se refresca sola; el aviso push con la app cerrada espera al build propio de distribución.